VULNERABILITY ASSESSMENT USING NESSUS

A Hands-On Lab Documentation on Scanner Deployment, Policy Configuration, Target Assessment, Finding Analysis and Remediation Planning

Submitted By	Mayank Raj
Course	Master of Computer Applications (MCA)
Specialization	Cyber Security
Institute	Skillected, Pune, Maharashtra

Scanner Platform	Tenable Nessus Essentials 19.16.1 (build 20021) on Kali Linux
Console Address	https://127.0.0.1:8834
Target Assessed	10.118.110.18 (authorized lab host)
Date of Execution	19 – 20 September 2026
Document Version	1.0

Authorization Statement: The vulnerability assessment recorded in this report was carried out against a host inside a private lab environment owned by the author. Nessus performs active probing and authenticated inspection; running it against systems without documented permission from the asset owner is unlawful in most jurisdictions and is outside the scope of this exercise.

Table of Contents

Sec.	Title	Page
1	Introduction	3
2	Objectives of the Assessment	3
3	Scope and Lab Setup	3
4	Install Nessus Essentials	5
5	Configure Scan Policy	7
6	Scan Target	9
7	Analyze Vulnerabilities	10
8	Generate Report	12
9	Recommend Mitigations	13
10	Consolidated Assessment Summary	15
11	Analysis and Observations	16
12	Conclusion	17
13	Learning Outcomes	17
14	References	17

List of Screenshots

Fig.	Description	Section
4.1	Nessus service started and running on Kali Linux	4
4.2	Nessus web interface initializing and downloading plugins	4
5.1	Nessus Essentials dashboard with an empty My Scans folder	5
5.2	Basic Network Scan policy configured with the target address	5
6.1	Scan in progress against 10.118.110.18 in the Hosts view	6
7.1	Vulnerabilities tab populating while the scan is still running	7
7.2	Completed vulnerability listing grouped by plugin family	7
8.1	Final host summary and severity distribution after completion	8
9.1	Remediations tab listing consolidated corrective actions	9

1. Introduction

Network mapping answers the question of what is reachable. Vulnerability assessment answers the far more consequential question of what is *weak*. Tenable Nessus is a vulnerability scanner that automates this second stage: it identifies the software installed on a target, compares each product and version against a continuously updated plugin database of known flaws, and reports the resulting findings ranked by severity.

Nessus Essentials is the free tier of the product, licensed for up to sixteen IP addresses, which makes it well suited to a student lab. This document records a complete assessment cycle performed from a Kali Linux host: installing and starting the scanner service, configuring a scan policy, executing the scan against an authorized target, interpreting the findings, exporting a report and translating the raw output into prioritised remediation guidance.

An important characteristic of this particular assessment is that the scan was **credentialed**. Nessus authenticated successfully to the target rather than probing it purely from the outside, which is why the results are far richer than a network-only scan of the same host would produce.

2. Objectives of the Assessment

- Install and initialise Tenable Nessus Essentials on the Kali Linux assessment host.
- Verify that the scanner service is active and that the plugin feed has been downloaded.
- Create and configure a Basic Network Scan policy targeting an authorized lab address.
- Execute the scan and monitor its progress through the Nessus web console.
- Analyse the returned findings by severity, plugin family and affected product.
- Generate and export a structured assessment report from the completed scan.
- Derive a prioritised set of remediation actions from the scanner's output.
- Distinguish genuine security exposures from purely informational findings.

3. Scope and Lab Setup

Parameter	Detail
Scanner host	Kali Linux, Nessus Essentials 19.16.1 (build 20021)
Web console	https://127.0.0.1:8834 (local loopback only)
Scan name	Nessus Lab Vulnerability Scan
Policy template	Basic Network Scan
Severity base	CVSS v3.0
Scanner type	Local Scanner
Target	10.118.110.18
Authentication	Credentialed — host reported as **Pass**
Scan window	12:09 AM – 12:31 AM (elapsed 22 minutes)
Out of scope	Exploitation, privilege escalation, data extraction, any other host

The choice of the *Basic Network Scan* template is deliberate. It enables a broad, general-purpose plugin set with safe checks only, which is the appropriate starting point for a first assessment. More aggressive templates exist, but they can destabilise services and are not suitable for an unhardened lab target.

4. Install Nessus Essentials

Objective

Deploy the Nessus scanner on the assessment host, start its service and confirm that the plugin database has been retrieved.

Commands

```
$ sudo systemctl start nessusd
$ sudo systemctl status nessusd
```

Explanation

Nessus runs as a background daemon named **nessusd** that serves a web console on TCP port 8834. The service is installed disabled by default, so it must be started explicitly. Checking the status immediately afterwards confirms three things at once: that the unit reached the *active (running)* state, that the nessus-service process spawned under the correct PID, and that the daemon logged a clean startup banner with its build number.

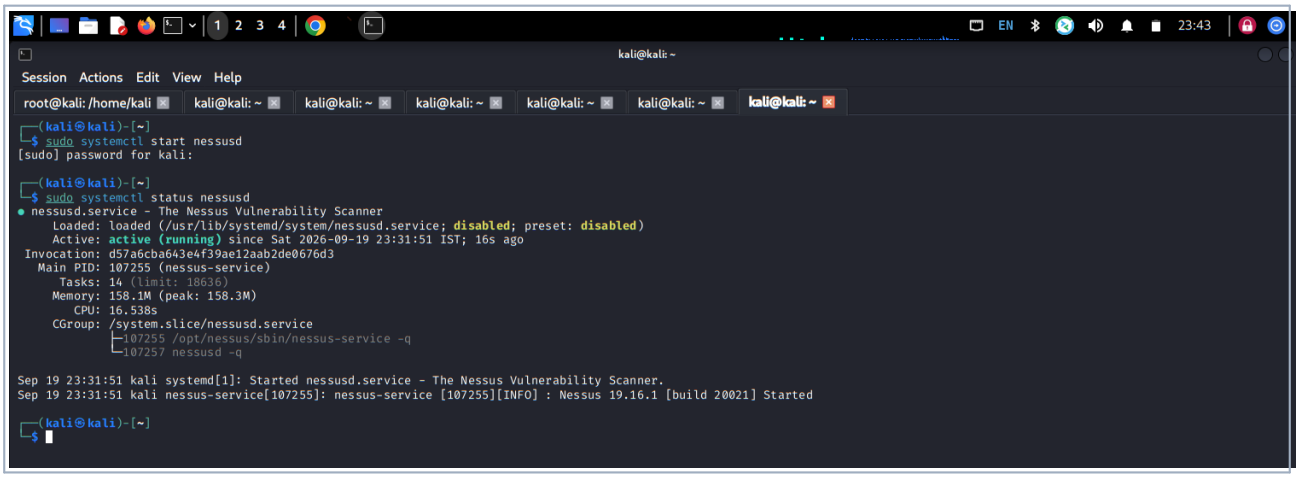


Fig 4.1 — nessusd started and confirmed active, running Nessus 19.16.1 build 20021 with the service process listed under its control group.

On first launch the console performs a one-time initialisation. Nessus registers the Essentials activation code and then downloads and compiles its plugin feed — tens of thousands of NASL scripts, each encoding the detection logic for a specific vulnerability. This step is mandatory: until the feed is compiled the scanner has no knowledge base to test against, and any scan launched early would return misleadingly sparse results.

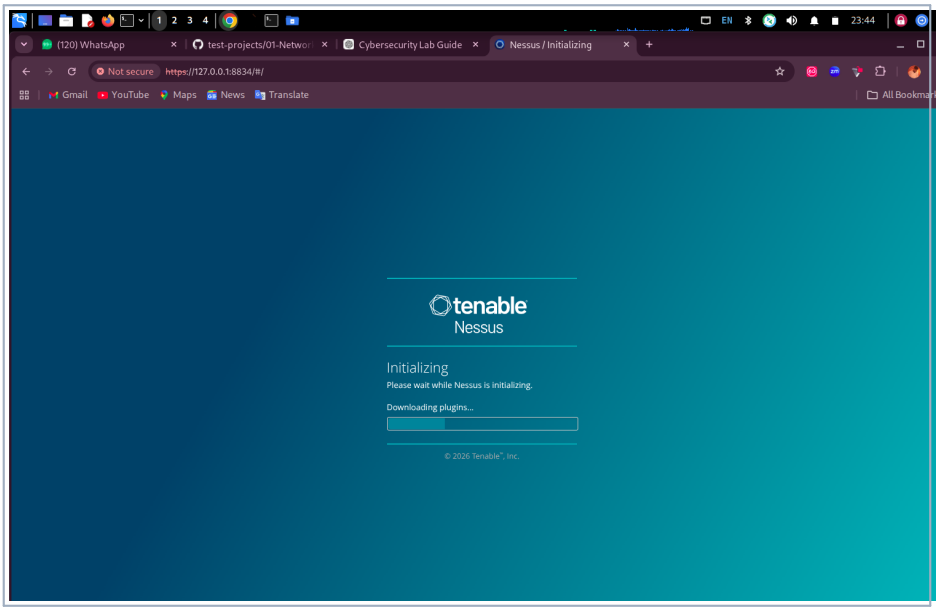


Fig 4.2 — The Nessus web console at 127.0.0.1:8834 initialising and downloading its plugin feed.

Result

Nessus Essentials was installed successfully, the service reached the running state within seconds, and the plugin feed downloaded without error. The scanner is ready for policy configuration.

5. Configure Scan Policy

Objective

Define what will be scanned, how it will be scanned, and where the results will be stored.

Procedure

- Log in to the console and open the **My Scans** folder, which is empty on a fresh install.
- Select **New Scan** and choose the **Basic Network Scan** template.
- Name the scan, add a description, and confirm the destination folder.
- Enter the authorized target address in the Targets field and save the configuration.

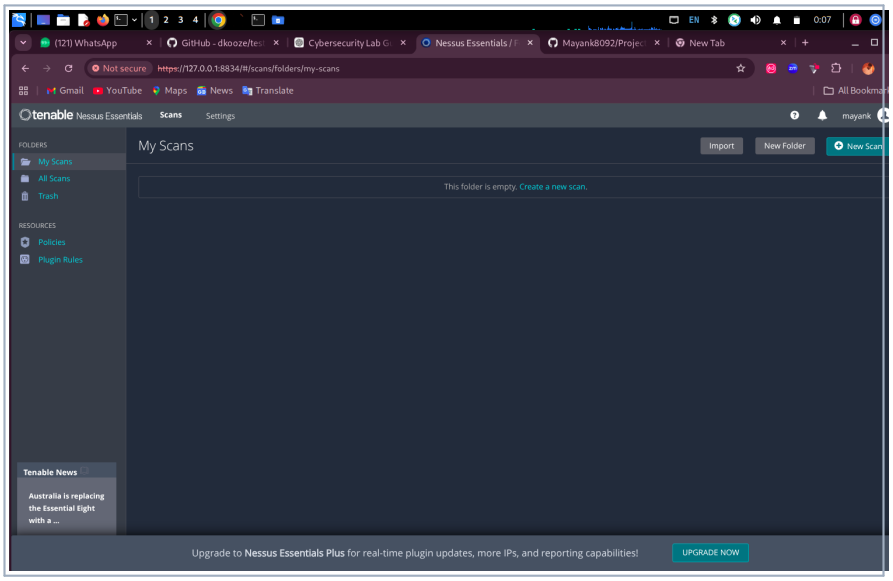


Fig 5.1 — The Nessus Essentials console with an empty My Scans folder, ready for a new scan to be created.

Explanation

A Nessus scan is the combination of a *template*, which determines which plugin families and probing behaviour apply, and a *target list*, which determines what those plugins are pointed at. The settings pane exposes further groups — Discovery controls host and port enumeration, Assessment governs how aggressively web and database checks run, Report shapes the output, and Advanced tunes timing and concurrency. For this exercise the template defaults were retained so the results reflect standard scanner behaviour rather than a hand-tuned configuration.

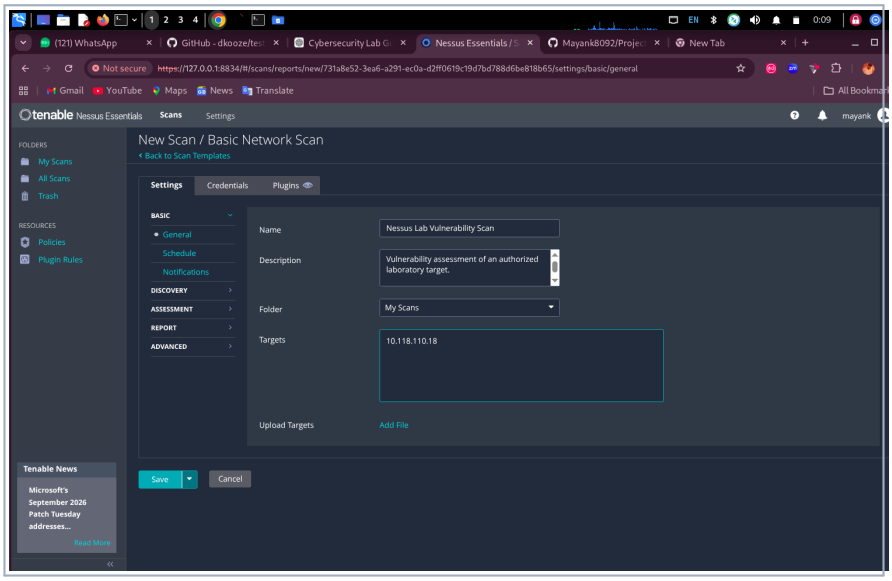


Fig 5.2 — Basic Network Scan configured as 'Nessus Lab Vulnerability Scan' with target 10.118.110.18.

Result

The scan policy was saved with a single authorized target. Restricting the target field to one address is a deliberate safety control: a mistyped subnet mask here is the most common way a lab scan escapes its intended boundary.

6. Scan Target

Objective

Execute the configured scan against the target and monitor its progress to completion.

Explanation

Launching the scan starts a staged process. Nessus first confirms the host is alive, then enumerates open ports, then fingerprints the services behind them, then authenticates using the supplied credentials, and only then begins firing vulnerability plugins. Findings stream into the console as they are confirmed, so the Hosts and Vulnerabilities views populate progressively rather than appearing all at once at the end.

The severity bar beside the host is the quickest read on progress. Each coloured segment represents a severity band, and watching the counts climb gives an early indication of the target's overall posture well before the scan finishes.

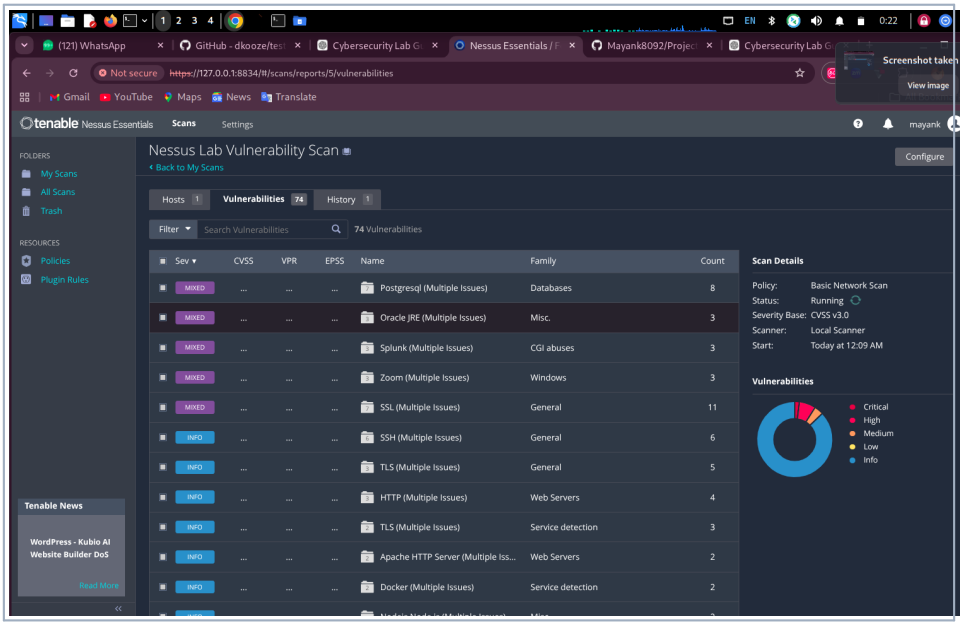


Fig 6.1 — Scan in progress against 10.118.110.18. Authentication shows Pass, and the severity bar has reached 9 / 5 / 113 at roughly 99% completion.

Observation

Field	Value
Target host	10.118.110.18
Authentication	Pass — credentialed scan succeeded
Status during capture	Running
Findings at capture	9 high-severity, 5 medium, 113 informational
Start time	12:09 AM

Result

The scan ran to completion in 22 minutes. The **Pass** authentication status is the single most significant detail in this view, because it confirms Nessus was able to log in to the target and inspect installed software directly instead of inferring it from network banners.

7. Analyze Vulnerabilities

Objective

Interpret the returned findings and separate genuine exposures from informational noise.

Explanation

The Vulnerabilities tab groups findings by plugin family rather than listing every individual plugin hit. A row labelled *Multiple Issues* with a count beside it represents several related plugins collapsed into one entry, which keeps the view readable but means the row count and the true finding count differ. Nessus assigns each finding a severity of Critical, High, Medium, Low or Info, scored here against the CVSS v3.0 base metric.

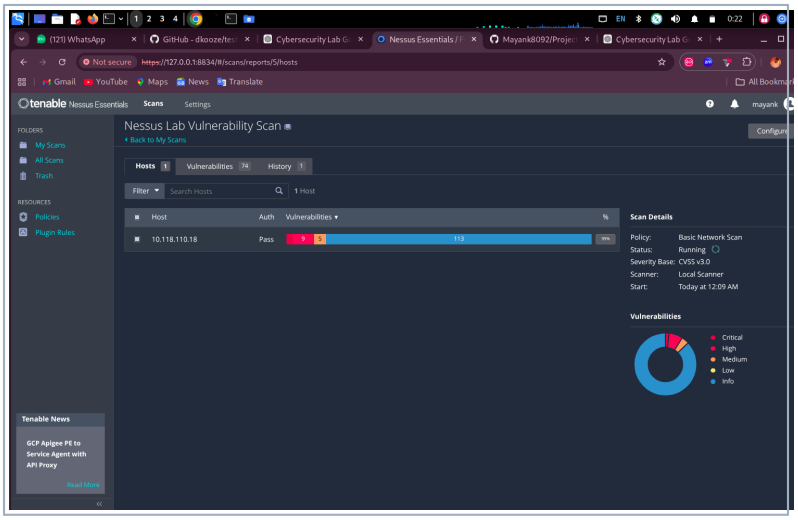


Fig 7.1 — The Vulnerabilities tab populating mid-scan, with 74 grouped entries recorded at the time of capture.

The **Info** severity deserves particular care. Informational plugins are not vulnerabilities; they record facts the scanner discovered, such as a detected service, a certificate subject or an enumerated software inventory. They dominate the count by volume but carry no risk on their own. Judging a host by its total finding count rather than its severity distribution is the most common misreading of a Nessus report.

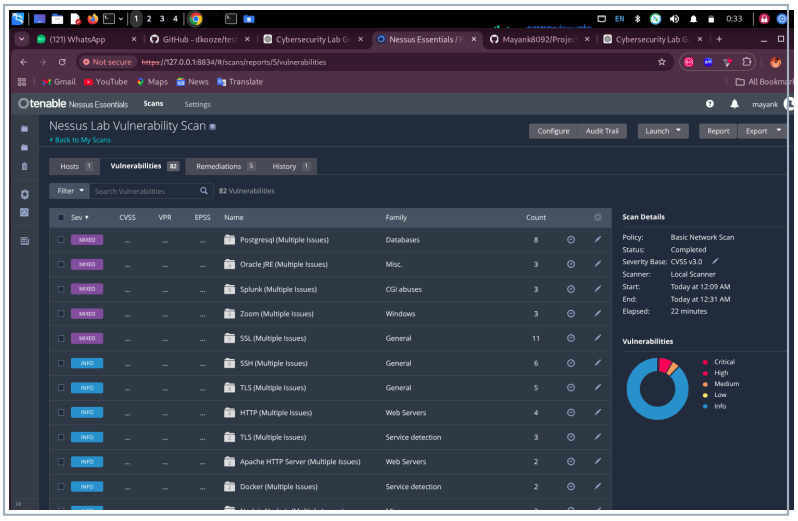


Fig 7.2 — Completed scan showing 82 grouped vulnerability entries across database, web, cryptographic and application plugin families.

Observation — Affected Product Families

Plugin family	Product	Grouped count	Severity band
Databases	PostgreSQL	8	Mixed
Misc.	Oracle JRE	3	Mixed
CGI abuses	Splunk	3	Mixed
Windows	Zoom	3	Mixed
General	SSL	11	Mixed
General	SSH	6	Info
General / Service detection	TLS	5 and 3	Info
Web Servers	HTTP	4	Info
Web Servers	Apache HTTP Server	2	Info
Service detection	Docker	2	Info

Result

Four product families carry mixed-severity findings and therefore warrant action: PostgreSQL, Oracle JRE, Splunk and the SSL/TLS configuration. The SSH, HTTP, Apache and Docker entries are detection plugins recording what is installed, not weaknesses to fix.

8. Generate Report

Objective

Produce a durable, shareable record of the completed assessment.

Procedure

- Open the completed scan and review the **Hosts** tab for the per-host severity summary.
- Use **Report** to render a formatted document directly from the console.
- Use **Export** to produce a portable file — Nessus (.nessus) for re-import into a scanner, or CSV for spreadsheet analysis and tracking.
- Retain the **History** entry so the current scan can be compared against future runs.

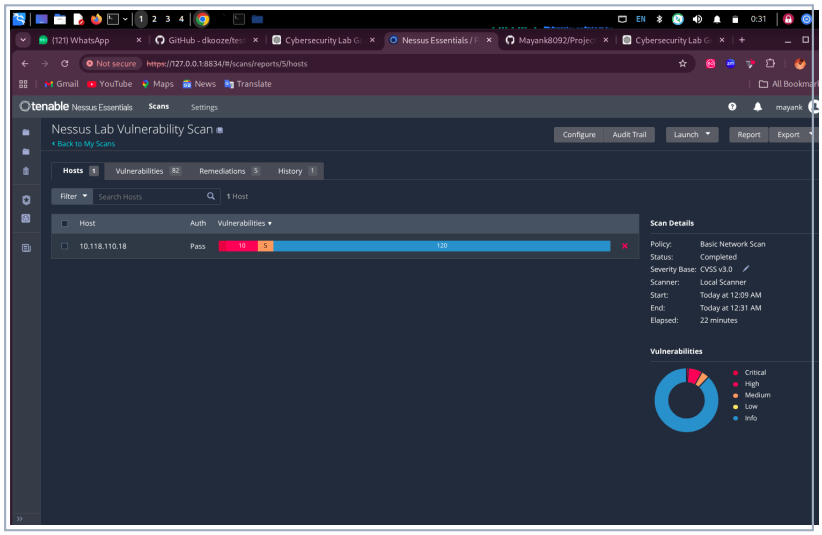


Fig 8.1 — Completed scan summary for 10.118.110.18 showing the final severity distribution and the Report and Export controls.

Observation — Final Scan Metrics

Metric	Value
Hosts assessed	1
Grouped vulnerability entries	82
Consolidated remediation actions	5
High-severity findings	10
Medium-severity findings	5
Informational findings	120
Scan status	Completed
Elapsed time	22 minutes (12:09 AM – 12:31 AM)

Result

The assessment produced 135 individual findings across three severity bands. Of these, only 15 carry a severity above informational, and those 15 are the actionable output of the entire exercise. Exporting in both report and CSV form preserves the evidence and allows remediation progress to be tracked item by item.

9. Recommend Mitigations

Objective

Convert the scanner's findings into a prioritised, actionable remediation plan.

Explanation

The Remediations tab is the most operationally useful view in Nessus. Rather than listing findings one by one, it collapses them into the smallest set of corrective actions that would clear the largest number of issues. A single Oracle Java patch, for example, resolves dozens of individual plugin hits at once. This is what allows a defender to work in order of impact instead of chasing findings individually.

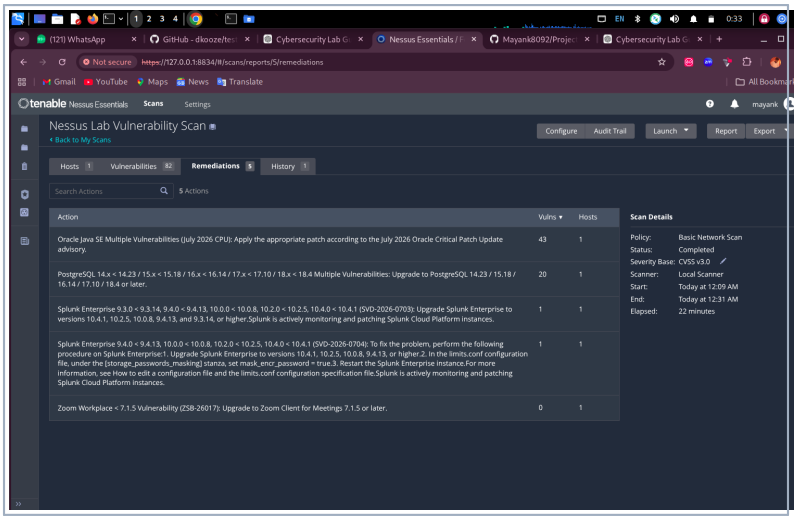


Fig 9.1 — Remediations tab consolidating the 82 grouped findings into five corrective actions.

Prioritised Remediation Plan

Pri.	Action	Vulns resolved	Basis
P1	Apply the July 2026 Oracle Critical Patch Update to Oracle Java SE.	43	Largest single reduction in exposure; Java flaws are widely weaponised.
P2	Upgrade PostgreSQL to 14.23 / 15.18 / 16.14 / 17.10 / 18.4 or later.	20	Database engine holds the most sensitive data on the host.
P3	Upgrade Splunk Enterprise to 10.4.1 / 10.2.5 / 10.0.8 / 9.4.13 / 9.3.14 or higher (SVD-2026-0703).	1	Vendor-published advisory with a fixed release available.
P4	Upgrade Splunk Enterprise per SVD-2026-0704 and set `mask_encr_password = true` in the `[storage_passwords_masking]` stanza of limits.conf, then restart the instance.	1	Requires a configuration change in addition to the upgrade.
P5	Upgrade Zoom Client for Meetings to 7.1.5 or later (ZSB-26017).	0	Client-side software; lower exposure but trivially patched.

Result

Five actions address the entire actionable finding set. Executing P1 and P2 alone would resolve 63 of the individual findings, which illustrates why remediation should always be sequenced by consolidated impact rather than by scrolling through the vulnerability list.

10. Consolidated Assessment Summary

10.1 Assessment Workflow

#	Phase	Action Performed	Outcome
1	Install	systemctl start / status nessusd	Service active, plugins downloaded
2	Configure	Basic Network Scan policy created	Target 10.118.110.18 saved
3	Scan	Scan launched from console	Completed in 22 minutes, auth Pass
4	Analyze	Findings reviewed by family and severity	82 grouped entries reviewed
5	Report	Report generated and exported	Evidence retained for tracking
6	Remediate	Remediations tab reviewed	5 prioritised actions defined

10.2 Severity Distribution

Severity	Count	Share of findings	Requires action
High	10	7.4%	Yes — patch immediately
Medium	5	3.7%	Yes — schedule
Informational	120	88.9%	No — inventory data only
Total	**135**	**100%**	**15 actionable**

10.3 Key Findings

- **F-01 — Outdated Oracle Java runtime.** The largest single contributor to the host's exposure, accounting for 43 individual findings resolvable by one patch.
- **F-02 — Unpatched PostgreSQL instance.** Twenty findings against the database engine, all cleared by a single minor-version upgrade.
- **F-03 — Splunk Enterprise below fixed release.** Two advisories apply, one of which additionally requires a configuration change to mask stored passwords.
- **F-04 — SSL/TLS configuration weaknesses.** Eleven grouped SSL entries at mixed severity indicate legacy protocol or cipher support that should be reviewed.
- **F-05 — Credentialed access materially changed the result.** The authenticated scan enumerated installed software directly, surfacing issues an unauthenticated network scan of the same host would not have detected.
- **F-06 — Informational findings dominate by volume.** Nearly 89% of findings carry no risk and must not be counted as vulnerabilities in any summary metric.

11. Analysis and Observations

The most instructive aspect of this assessment is the contrast between what an external network scan reveals and what an authenticated vulnerability scan reveals. A host can present a hardened network face while simultaneously running a substantial stack of outdated software underneath. Perimeter filtering limits who can reach a flaw; it does not remove the flaw. Any assessment that stops at the network layer will systematically understate risk on a well-firewalled host.

The findings themselves follow a familiar pattern. Every actionable item on this host traces back to software that is simply behind its vendor's current release. None required exotic analysis, and none required exploitation to confirm. Patch currency, not sophisticated attack technique, is where the practical risk sits.

Ref	Observation	Recommendation
R-01	Multiple products running below their fixed versions.	Establish a monthly patch cycle covering Java, PostgreSQL, Splunk and endpoint clients; track each against its vendor advisory.
R-02	Assessment performed from a single scan run.	Schedule recurring scans and use the History tab to trend severity counts over time rather than treating one scan as a verdict.
R-03	SSL/TLS entries at mixed severity.	Audit the cipher suite and protocol configuration; disable legacy protocol versions and weak ciphers, and replace any self-signed certificate on a production path.
R-04	Credentialed scanning proved substantially more informative.	Retain credentialed scanning as the default. Uncredentialed scans should supplement it, not replace it.
R-05	Scan coverage limited to one host on one template.	Extend coverage to the full authorized address range and consider a compliance or web application template alongside the basic network scan.
R-06	No evidence of remediation verification.	Re-scan after each patch window and confirm the corresponding finding has cleared; remediation is not complete until the scanner agrees.

12. Conclusion

This exercise carried a full vulnerability assessment lifecycle from deployment to remediation planning. Nessus Essentials was installed and initialised on Kali Linux, a Basic Network Scan policy was configured against an authorized lab target, the scan was executed and monitored to completion, the findings were analysed by severity and product family, a report was generated for retention, and the output was distilled into five prioritised corrective actions.

The target host produced 135 findings in 22 minutes, of which 15 were genuinely actionable and five remediation actions were sufficient to address them all. The exercise demonstrated that the value of a vulnerability scanner lies less in the volume of data it produces than in the analyst's ability to rank that data correctly — to recognise that an informational plugin is not a vulnerability, that a single patch can clear dozens of findings, and that a successful authentication is what separates a superficial scan from a meaningful one.

13. Learning Outcomes

- Learned to deploy and initialise Nessus Essentials, and why the plugin feed must finish compiling before any scan is meaningful.
- Understood how a scan template and a target list combine to define a Nessus scan, and why restricting the target field is a safety control.
- Learned to read the severity distribution rather than the raw finding count, and to treat Info-level plugins as inventory data.
- Recognised the practical difference between credentialed and uncredentialed scanning, and the risk of understating exposure without authentication.
- Learned to use the Remediations view to sequence fixes by consolidated impact instead of working down an unsorted vulnerability list.
- Understood that remediation is only complete once a follow-up scan confirms the finding has cleared.

14. References

- Tenable Nessus Documentation — https://docs.tenable.com/nessus/
- Nessus Essentials Product Page — https://www.tenable.com/products/nessus/nessus-essentials
- FIRST, Common Vulnerability Scoring System v3.1 Specification — https://www.first.org/cvss/
- Oracle Critical Patch Update Advisories — https://www.oracle.com/security-alerts/
- PostgreSQL Security Information — https://www.postgresql.org/support/security/
- Splunk Security Advisories — https://advisory.splunk.com/
- Kali Linux Documentation — https://www.kali.org/docs/